

TECHBASE GRC

Plano de Segurança

Cyberplanner · QNRCS / NIS2

EMPRESA

Techbase

SETOR

Tecnologia &
Software

DATA

30/04/2026

33%

Crítico

1

Implementado

1

Parcial

1

Gap

1

N/A

Gerado pelo Techbase GRC Cyberplanner · Documento confidencial · Uso interno.
As ações devem ser implementadas como tarefas, evidências e políticas no módulo GRC.

Plano de Ação

Techbase · 30/04/2026 · Score: 33% (Crítico)

Dados & Privacidade

Os dados sensíveis têm RBAC e MFA obrigatório nos sistemas críticos?	GAP Risco: Crítico
Ação: Aplicar least-privilege + MFA + revisão trimestral de contas privilegiadas.	ID: PDS_02 QNRCS: PR.AC-1 NIS2: Art. 21
Dados sensíveis são cifrados em repouso e em trânsito (TLS 1.2+)?	PARCIAL Risco: Alto
Ação: Rever cifragem AES/TLS, rotação de chaves e certificados HTTPS.	ID: PDS_03 QNRCS: PR.DS-1 NIS2: Art. 21

Itens não aplicáveis

PDS_01 – Existe inventário dos dados tratados (PII, saúde, financeiro) com localização e responsável?

Anexo – Mapeamento Completo (QNRCS / NIS2)

Techbase · 30/04/2026 · Todos os 31 controlos avaliados com estado, risco e referências normativas.

ID	Área	Controlo	Estado	Risco	QNRCS	NIS2	Ação recomendada
PDS_01	Dados & Privacidade	Existe inventário dos dados tratados (PII, saúde, financeiro) com localização e responsável?	N/A	Crítico	ID.GA-1	Art. 21	Criar registo de dados com tipo, localização, owner e classificação de criticidade.
PDS_02	Dados & Privacidade	Os dados sensíveis têm RBAC e MFA obrigatório nos sistemas críticos?	NÃO	Crítico	PR.AC-1	Art. 21	Aplicar least-privilege + MFA + revisão trimestral de contas privilegiadas.
PDS_03	Dados & Privacidade	Dados sensíveis são cifrados em repouso e em trânsito (TLS 1.2+)?	PARCIAL	Alto	PR.DS-1	Art. 21	Rever cifragem AES/TLS, rotação de chaves e certificados HTTPS.
PDS_04	Dados & Privacidade	Existe backup regular (3-2-1) com testes de restauração periódicos?	SIM	Crítico	PR.IP-4	Art. 21	Backups diários off-site + testes mensais + evidências documentadas.
NS_01	Segurança de Rede	Firewall com regras documentadas e revisão periódica de portas expostas?	—	Alto	PR.AC-4	Art. 21	Auditar regras, fechar portas desnecessárias, manter inventário de serviços.
NS_02	Segurança de Rede	Wi-Fi corporativo usa WPA2/WPA3 com rede de convidados separada?	—	Alto	PR.AC-1	Art. 21	VLAN guest isolada, senha robusta, desativar WPS.
NS_03	Segurança de Rede	Acessos remotos obrigam VPN segura com MFA?	—	Crítico	PR.AC-1	Art. 21	VPN + MFA + políticas por função + logging de acessos.
NS_04	Segurança de Rede	Processo de patching mensal com priorização CVSS e evidências?	—	Alto	PR.IP-12	Art. 21	Janela de patching definida, criticidade CVSS, registo de evidências.
EM_01	Email & Comunicações	Filtros anti-spam/phishing ativos e domínio com SPF, DKIM e DMARC?	—	Alto	PR.DS-2	Art. 21	Filtros avançados + SPF + DKIM + DMARC (evoluir para p=reject).
EM_02	Email & Comunicações	Equipa recebe formação anti-phishing com	—	Alto	PR.AT-1	Art. 21	Programa de awareness semestral +

ID	Área	Controlo	Estado	Risco	QNRCS	NIS2	Ação recomendada
		simulações periódicas?					simulações + registo de participação.
EM_03	Email & Comunicações	Bloqueio de anexos perigosos (exe, macro) e política de retenção?	—	Médio	PR.IP-1	Art. 21	Bloquear extensões perigosas, sandbox para anexos, retenção 90 dias.
EMP_01	Pessoas & Acessos	Onboarding/offboarding formal com remoção de acessos em < 24h na saída?	—	Crítico	PR.AC-4	Art. 21	Checklist formal + revogação automática de acessos ao fim de 24h.
EMP_02	Pessoas & Acessos	Contas admin separadas do dia-a-dia, com MFA e auditadas trimestralmente?	—	Crítico	PR.AC-1	Art. 21	Contas admin dedicadas + MFA + logs + revisão trimestral.
EMP_03	Pessoas & Acessos	Política de passwords com requisitos mínimos e gestor corporativo?	—	Alto	PR.AC-1	Art. 21	Política 12+ caracteres + MFA + gestor de passwords corporativo.
EMP_04	Pessoas & Acessos	Colaboradores assinaram AUP e recebem formação de segurança anual?	—	Médio	GV.PO-1	Art. 21	AUP atualizada + assinaturas + formação anual com registo.
IR_01	Resposta a Incidentes	Plano de resposta a incidentes documentado com papéis e playbooks?	—	Crítico	RS.RP-1	Art. 21	Criar IRP com papéis, contactos de emergência e playbooks por tipo.
IR_02	Resposta a Incidentes	Logging centralizado com retenção ≥ 90 dias e alertas de anomalias?	—	Alto	DE.CM-1	Art. 21	SIEM ou equivalente, retenção 90+ dias, alertas automáticos.
IR_03	Resposta a Incidentes	RTO/RPO definidos para serviços críticos e testados anualmente?	—	Médio	PR.PT-4	Art. 21	Definir RTO/RPO + teste anual de recuperação + evidências.
IR_04	Resposta a Incidentes	Plano de comunicação de incidentes ao CNCS/ autoridades (NIS2)?	—	Médio	RS.CO-2	Art. 23	Template de comunicação + contactos CNCS + notificação em 24h.
SUP_01	Fornecedores & Terceiros	Inventário de fornecedores	—	Alto	ID.SC-1	Art. 21	Registo de fornecedores com

ID	Área	Controlo	Estado	Risco	QNRCS	NIS2	Ação recomendada
		críticos com avaliação de risco?					criticidade, tipo de acesso e owner.
SUP_02	Fornecedores & Terceiros	Contratos incluem cláusulas de segurança, SLA e notificação de incidentes?	—	Médio	ID.SC-2	Art. 21	Cláusulas de segurança + SLA + auditoria em todos os contratos.
SUP_03	Fornecedores & Terceiros	Acessos de terceiros são limitados, temporários e revogados ao fim?	—	Alto	PR.AC-1	Art. 21	Least-privilege + MFA + expiração automática + logs por fornecedor.
POL_01	Políticas & Governança	Políticas formais (passwords, acessos, backups, IR) versionadas e aprovadas?	—	Alto	GV.PO-1	Art. 21	Criar e versionar políticas base, com aprovação da gestão e revisão anual.
POL_02	Políticas & Governança	Inventário de ativos (hardware, software, dados) com owners e criticidade?	—	Alto	ID.GA-1	Art. 21	Manter inventário atualizado com tipo, owner, criticidade e localização.
POL_03	Políticas & Governança	Registo de riscos com P×I, plano de tratamento e responsável?	—	Médio	ID.RA-1	Art. 21	Criar registo de riscos com matriz P×I, ações, prazos e evidências.
WS_01	Web & Serviços Públicos	Serviços públicos com TLS 1.2+, HSTS e security headers configurados?	—	Alto	PR.DS-2	Art. 21	Verificar TLS, HSTS, CSP, X-Frame-Options e Referrer-Policy.
WS_02	Web & Serviços Públicos	CMS, plugins e dependências atualizados com monitorização CVE?	—	Alto	PR.IP-12	Art. 21	Updates semanais + inventário de dependências + alertas CVE.
WS_03	Web & Serviços Públicos	WAF ativo e pentest anual documentado?	—	Médio	ID.RA-1	Art. 21	WAF com regras OWASP + proteção DDoS + pentest anual.
MD_01	Dispositivos Móveis	Dispositivos corporativos com bloqueio automático, PIN e cifragem ativa?	—	Médio	PR.AC-1	Art. 21	Política de bloqueio 30s + PIN forte + cifragem obrigatória.
MD_02	Dispositivos Móveis	MDM implementado com inventário, baseline e wipe remoto?	—	Alto	PR.IP-1	Art. 21	MDM (Intune/Jamf) + baseline de segurança + wipe remoto.
MD_03	Dispositivos Móveis	Política BYOD formal com	—	Médio	PR.AC-1	Art. 21	Política BYOD com

ID	Área	Controlo	Estado	Risco	QNRCS	NIS2	Ação recomendada
		separação de dados corporativos?					containerização, requisitos mínimos e aceitação.